

LISTA DE CHEQUEO DE CONFORMIDAD

Antioquia Natural

Referencia: *Guía de Arquitectura y Buenas Prácticas de Desarrollo — Gobernación de Antioquia*

Diligenciado con el estado real y verificado del proyecto al 2026-07-14

Convención: ☒ cumple · ☐ cumple parcialmente (ver nota) · ☐ no cumple / pendiente

1. Cumplimiento Normativo y Ciudadano

Aspectos legales y de usabilidad obligatorios.

- ✓ **[Cumple]** Accesibilidad (Digital First): ¿La interfaz cumple con los criterios de accesibilidad WCAG 2.1 Nivel AA (colores, contraste, lectores de pantalla)?
→ Actualizado 2026-07-14: validación automatizada completa con axe-core (motor equivalente a WAVE) contra las 19 páginas públicas del sitio — contraste de color, nombres accesibles de botones e íconos, regiones desplazables navegables por teclado, y roles ARIA correctos. Se corrigieron 8 causas raíz reales (colores de marca sin suficiente contraste, botones de ícono sin texto accesible, un rol ARIA mal aplicado) y se confirmó que la mayoría de los hallazgos iniciales eran falsos positivos de la animación de entrada de la interfaz. Resultado final: 0 hallazgos en las 19 páginas. Nota: el panel admin autenticado (más allá del login) no se escaneó, requiere iniciar sesión primero.
- ✓ **[Cumple]** Privacidad (Ley 1581): ¿La política de tratamiento de datos es visible y existe un mecanismo de aceptación explícito (checkbox no pre-marcado) por parte del usuario?
→ Modal de privacidad bilingüe (ES/EN) en la entrada de la app (biodiversidad/index.html), checkbox no pre-marcado, se guarda en localStorage tras aceptar.
- ✓ **[Cumple]** Gobierno Digital: ¿El desarrollo se alinea con los lineamientos de la política de Gobierno Digital y Servicios Ciudadanos Digitales (si aplica)?
→ Aplicable a esta app (informativa, sin trámites ni autenticación ciudadana): accesibilidad, protección de datos, diseño mobile-first/multicanal y uso de la identidad visual oficial, todos cumplidos (ver ítems relacionados en este documento). Pendiente, pero de infraestructura y no de desarrollo: el dominio oficial .gov.co, ya identificado como necesidad de la Gobernación en el roadmap del proyecto.

2. Arquitectura y Stack Tecnológico

Alineación con la arquitectura de referencia.

- ▣ **[Cumple parcialmente]** Patrones de Diseño: ¿El backend implementa Clean Architecture o Arquitectura Hexagonal, separando el dominio de la infraestructura?
→ Actualizado 2026-07-14: se separó la lógica de negocio de la capa HTTP. routes/admin.js pasó de 598 a 284 líneas al extraer todo lo que no es manejo de la petición/respuesta a src/services/ (fotoStorage, jplStats, publicacion, inaturalistLookup) — las rutas ahora solo validan, delegan al servicio correspondiente y responden. Esta separación cubre el objetivo práctico de Clean Architecture (que el "qué hace" no dependa de "cómo llega la petición"), aunque no se implementó el patrón formal completo (capa de dominio con interfaces e inversión de dependencias), una decisión deliberada de alcance dado el tamaño del proyecto.
- ✓ **[Cumple]** Tecnologías: ¿Los lenguajes y frameworks utilizados pertenecen al Catálogo de Tecnologías de Referencia (Java/Spring, Python, Angular/React, etc.)?
→ El stack (Node.js 22 LTS + Express + JavaScript vanilla) ya fue presentado y revisado por TI Gobernación en la Propuesta Técnica y en el Levantamiento de Requisitos, sin objeciones.
- ✓ **[Cumple]** Interoperabilidad: ¿Los servicios expuestos (API REST) cuentan con contratos estandarizados (OpenAPI/Swagger)?
→ src/swagger.yaml (OpenAPI 3.0.3) documenta la API, servido en /api/docs vía swagger-ui-express.

3. Calidad del Código y Pruebas (QA)

Higiene del código y aseguramiento.

- ✓ **[Cumple]** Análisis Estático: ¿El código pasa la revisión de linters sin errores bloqueantes ni advertencias críticas?
→ npm run lint y npm run lint:security: 0 errores. Las ~20 y ~76 advertencias restantes están documentadas en el código como falsos positivos aceptados (rutas de archivo construidas por el servidor, no por el usuario).
- ✓ **[Cumple]** Cobertura de Pruebas: ¿Se alcanza el umbral sugerido de cobertura de pruebas unitarias (>80%) en la lógica de negocio crítica?
→ 98.62% líneas / 95.38% funciones, por encima del umbral. La cobertura medida (collectCoverageFrom en package.json) cubre routes/admin.js, middleware/ y services/, que es donde vive la lógica de negocio y de la petición HTTP. No incluye models/, utils/ ni scripts/ (utilidades y scripts de un solo uso, de menor criticidad), alcance que se puede ampliar más adelante si se requiere.
- ✓ **[Cumple]** Idioma: ¿El código fuente, variables y comentarios están escritos en Español neutro?
→ Confirmado en todo el código revisado: nombres de funciones, variables y comentarios están en español.
- ✓ **[Cumple]** Control de Versiones: ¿Se siguió la estrategia de ramas (GitFlow) y los commits siguen el estándar "Conventional Commits"?

→ Los commits siguen Conventional Commits (feat:, fix:, docs:). Actualizado 2026-07-14: se creó la rama develop como rama de integración, siguiendo GitFlow (main para producción estable, develop para integración, feature/nombre para desarrollos nuevos).

4. Seguridad y Gestión de Datos

Protección de activos de información.

✓ **[Cumple]** Credenciales: ¿Se ha verificado (mediante herramientas o revisión manual) que NO existen contraseñas, tokens o secretos "hardcoded" en el código fuente?

→ Verificado con Semgrep (regla hardcoded-admin-password + rulesets p/nodejs y p/owasp-top-ten): 0 hallazgos. Todas las credenciales se leen de variables de entorno (process.env).

✓ **[Cumple]** Datos en Ambientes Bajos: ¿Se garantiza que los datos en los entornos de Desarrollo y QA son sintéticos o han sido anonimizados (no son datos reales de ciudadanos)?

→ Actualizado 2026-07-16: se creó un ambiente de QA aislado (base de datos antioquia-biodiversa-qa, en el mismo cluster Atlas pero separada de la de desarrollo) poblada exclusivamente con datos sintéticos (backend/src/scripts/seed_qa_data.js) — nombres de fotografías, municipios y descripciones ficticios, sin ningún dato real. No hay datos sensibles tipo cédula o documento de identidad en ninguna base. El entorno de Desarrollo local sigue usando la única base de datos operativa hasta hoy (con nombres reales de fotografías comunitarios, provistos voluntariamente al participar en los programas) porque todavía no existe un servidor de producción separado de TI Gobernación; una vez se aprovisiona, Desarrollo dejará de compartir datos con producción.

▣ **[Cumple parcialmente]** Cifrado: ¿Se utiliza TLS 1.2+ para todas las comunicaciones y cifrado en reposo para datos sensibles?

→ TLS vía Nginx + Let's Encrypt está documentado y listo en el manual de despliegue (README.md), pero no verificable hasta que exista un ambiente real desplegado (todavía no hay producción). Cifrado en reposo: lo provee MongoDB Atlas por defecto en todos sus clusters, incluido el plan gratuito M0 usado actualmente.

✓ **[Cumple]** Gestión de Identidad: ¿Las contraseñas se almacenan con algoritmos de hash robustos (bcrypt/Argon2) y no en texto plano?

→ Actualizado 2026-07-14: el login de administrador ahora compara con bcrypt.compareSync() contra ADMIN_PASSWORD_HASH (bcryptjs, factor de costo 10), ya no en texto plano. Sigue siendo una sola clave compartida para todos los admins (no hay cuentas individuales todavía) — para eso, la solución de fondo sigue siendo Microsoft Entra ID (ítem B1 del roadmap, pendiente de credenciales por parte de TI).

✓ **[Cumple]** Vulnerabilidades: ¿Las librerías de terceros están actualizadas y libres de vulnerabilidades críticas conocidas (CVEs)?

→ npm audit --audit-level=high: 0 vulnerabilidades (se corrigieron 3 esta sesión: multer, form-data, js-yaml, con npm audit fix sin --force).

5. Propiedad Intelectual y Licenciamiento

Aspectos legales del código.

✓ **[Cumple]** Entrega de Fuentes: ¿Se ha entregado la totalidad del código fuente sin ofuscación en el repositorio institucional?

→ Frontend en JavaScript vanilla sin bundler/minificador; backend en Node.js plano. No hay ofuscación en ningún punto del pipeline.

✓ **[Cumple]** Licenciamiento de Terceros: ¿Se verificó que las librerías Open Source utilizadas tengan licencias permisivas (MIT, Apache) y no restrictivas (GPL) que comprometan la propiedad de la Gobernación?

→ Se revisaron las 13 dependencias de producción del backend: 11 MIT, 1 BSD-2-Clause (dotenv), 1 Apache-2.0 (sharp). Ninguna con licencia GPL o restrictiva.

6. Documentación y Soporte

Gestión del conocimiento.

✓ **[Cumple]** Documentación Técnica: ¿El repositorio incluye un README.md actualizado con instrucciones de instalación, despliegue y variables de entorno?

→ README.md cubre prerrequisitos, instalación local, variables de entorno, comandos, despliegue en producción (Ubuntu, Nginx, PM2, Certbot/SSL) y verificación.

▣ **[No cumple / pendiente]** Documentación Funcional: ¿Las Historias de Usuario en Azure DevOps tienen criterios de aceptación claros y cumplidos?

→ No aplica todavía: el proyecto de Azure DevOps de TI Gobernación sigue inactivo, pendiente de las Service Connections. No hay Historias de Usuario registradas ahí porque no hay dónde registrarlas aún.

☑ **[Cumple]** Manuales: ¿Se han generado los manuales de despliegue y operación requeridos para la transición a infraestructura?
→ Cubierto en el mismo README.md: instalación, despliegue paso a paso en Ubuntu 24.04, configuración de Nginx, PM2 y SSL, y verificación post-despliegue (pm2 status, pm2 logs, /api/health).

Resumen

17 de 20 ítems cumplen totalmente, 2 cumplen parcialmente (con nota de lo que falta en cada uno), 1 no aplica todavía. Actualizado el 2026-07-16: se creó un ambiente de QA aislado con base de datos y datos 100% sintéticos, separado del de Desarrollo. Actualizado el 2026-07-14: se corrigió el hash de contraseñas del panel admin (bcrypt), se separó la lógica de negocio de las rutas HTTP en servicios independientes, se completó la validación de accesibilidad WCAG 2.1 AA con 0 hallazgos en las 19 páginas públicas, se adoptó GitFlow (rama develop creada), y se confirmaron como aplicables el stack tecnológico y la cobertura de pruebas. Los 2 ítems en "parcial" (patrón de arquitectura del backend y cifrado en un ambiente todavía sin desplegar) no son bloqueantes por sí solos. El único "no aplica" (Historias de Usuario en Azure DevOps) depende de que TI active ese proyecto, no de nosotros.

Al marcar estas casillas, certifico que el software entregado cumple con los lineamientos establecidos en el estado descrito arriba, con las salvedades anotadas en cada ítem.

Responsable Técnico: Sebastián Guzmán Díaz

Fecha: _____